Basic concepts

Ramin Sadre

What is security? The CIA triad

Properties a secure system should have:

- **Confidentiality**
  - Attacker cannot read/steal protected data
- **Integrity**
  - Attacker cannot modify protected data or the system behavior
- **Availability**
  - Attacker cannot disturb access to data or service

Vulnerabilities, threats, risks

- If your system is not secure it is **vulnerable**
  - Weak password
  - Software bug
  - …
- Vulnerabilities expose your system to **threats**
  - Attacker tries to guess password to log in
  - Attackers crashes your server with a wrong packet
  - …
- If your system is vulnerable and there are threats, somebody could **exploit** the vulnerability and there is the **risk** of damage
  - Your data will be stolen
  - Your server will be down
  - …

Threats

- Threats violate the desired security properties of your system

- **Information disclosure** Confidentiality
  - Obtain information that was not meant for unauthorized person
- **Tampering** Integrity
  - Modify data or system behavior against the intent of the user or service provider
- **Denial of service** Availability
  - Make data or service unavailable for legitimate users

- Note: Not all threats come from malicious actors (e.g., natural disasters, user errors,...)

Attacker and Threat Model

- To effectively protect a system, we need to understand the attackers' capabilities and motivations

Attacker Location

- **Local physical attacker**
  - Has temporary or permanent access to the target device
  - Might even take the device and analyze it at home
- **Local network attacker**
  - Located in the same bus, subnet, in wireless range
  - Can listen to or send network traffic to the device without being filtered by a firewall, proxy or authentical system
- **Remote attacker**
  - From the internet, from the IT network,...
  - Can access target via exposed services (open HTTP port,...)
- **Insider/supply-chain attacker**
  - Inside the developer company or component supplier
  - Has access to hardware design, firmware, user software

Technical Capabilities of Attacker

- Depending on attacker location, attacker might have different capabilities to perform attacks
- Physical access:
  - Fault injection with EM radiation, voltage manipulation,...
  - Reading out chips
- Local network:
  - Sniff traffic, send frames or packets
- Remote network:
  - Scanning company network for open ports, login to services
  - Denial of service attacks
- Insider/supply-chain attack
  - Can implant malware or vulnerabilities into software
  - Get cryptographic keys, certificates directly from manufacturer

STRIDE Threat Model

- **S**poofing: faking identity of a person, program, device by falsifying data
- **T**ampering: malicious modification of firmware, configuration files, memory
- **R**epudiation: lack of verifiable logs to prove that a user has or has not done something
- **I**nformation Disclosure: unauthorized disclosure of secrets, keys, code, client information,...
- **D**enial of Service: making a service unavailable by crashing, lockup, timing violation
- **E**levation of Privilege: account with limited privileges obtains privileges of more powerful account

Risk assessment

- Is your system vulnerable? What are the risks? What should you do?
- Steps:
  1. **Identify**: What are the critical assets in your system? (data, services,...) Who is responsible for them?
  2. **Assess**: What are the vulnerabilities and threats for your assets?
  3. **Analyze**: What is the risk if an attacker discovers the vulnerability? What would be the impact of a successful attack?
  4. **Decide**: Which risks do you want to treat first? And how?
  5. **Document** everything

Risk treatment

- Possible actions to handle a risk:
  - **Accept**: "It's okay if somebody steals our USB sticks"
  - **Avoid**: "We will stop using USB sticks"
  - **Transfer**: "I will call an external company to make our USB sticks secure"
  - **Treat**: "We will encrypt all files before putting them on USB sticks"

Security controls

- Security controls to treat risks
- Types of controls:
  - **Preventive controls**: put a lock on the door of the server room, encrypt files, use a firewall,...
  - **Detective controls**: log all login attempts, put a camera in the server room,...
  - **Compensating control**: shut down all servers when an attack has been detected,...
  - **Corrective controls**: change your password rules, update your software, restore the data from the backup,...

Security control categories

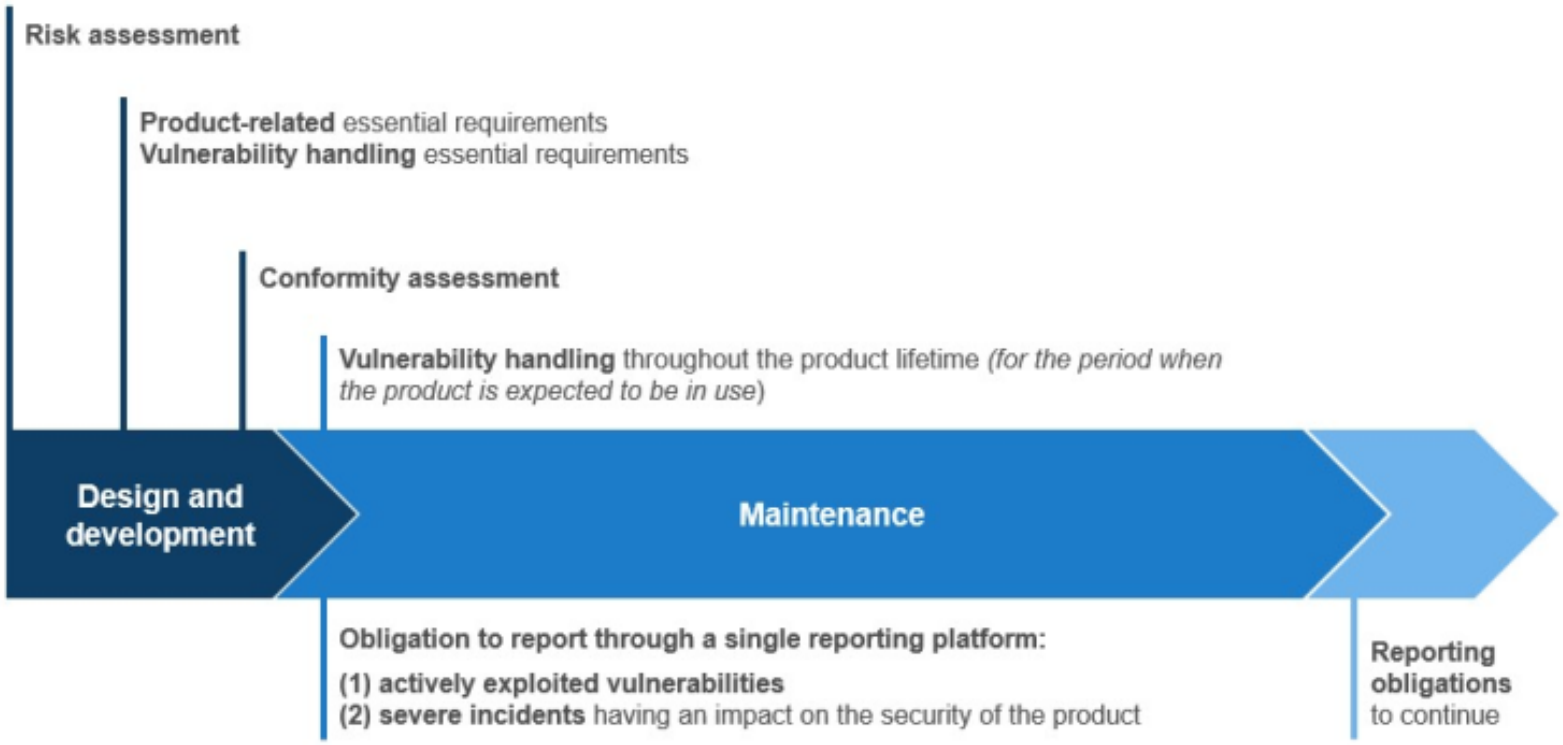
- Categories of security controls:
  - **Administative controls**: training of the users, make guidelines, make a risk assessment,...
  - **Physical controls:** fences, locks,...
  - **Technical controls**: use passwords, firewalls, encryption, antivirus,...
  - ...

This course

- There are many different ways to classify, plan, and implement security controls!
- There are standards and norms such as ISO/IEC 27000 and NIST SP-800 that define how risk assessment should be done, which controls to implement, how to document everything,...

EU Cyber Resilience Act (CRA)

- Defines rules to ensure that a product is secure during its entire lifetime



https://digital-strategy.ec.europa.eu/en/policies/cra-manufacturers

EU Cyber Resilience Act (CRA)

- Some principles of the CRA:
  - Security must be planned and managed already during the design and development phase of a product
  - Vulnerabilities and incidents must be reported
  - Risk assessment and implementing security controls is important https://eur-lex.europa.eu/legal-content/EN/TXT/HTML/?uri=OJ:L_202402847#anx_I

- Main **security requirements** principles:
  - Secure default configuration (no default password, etc.)
  - Manufacturer must provide updates
  - Protection from unauthorized access, protection of stored and transmitted data
  - Basic functions must resist Denial-of-Service attacks

Security control example: Access control

Access Control

- Against information disclosure (confidentiality) and tampering (integrity)
- Goal: Restrict access to a resource to specific users or programs
  - Resource can be data, CPU time, a service...
- In a computer system, there are many access control rules, for example:
  - Only the DB admin is allowed to delete a database table
  - Only the root user is allowed to change the password of a user
  - Only user “Peter” is allowed to read files from /home/peter

Implementing Access Control

- There are different ways to implement access control
- Typically, access control consists of:
  - **Authentication**: verify that the user/process is the person/program they claim to be
  - **Authorization**: define which access rights to resources the user/process has

Example: File systems

- File systems in Unix-like operating systems
  - Authentication with login and password
  - File permission flags specify who is the “owner” of a file and what a user is allowed to do with that file:

```
-rwxr-xr-x 1 ramin ramin 8328 Feb  1 23:16 test
-rw-r--r-- 1 ramin ramin  681 Feb  1 23:16 test.c
-rw-r--r-- 1 ramin ramin  233 Feb  6 13:31 test.py
-rw-rw-rw- 1 ramin ramin 2000 Apr 22  2020 test.txt
```

  - When a user (= a program started by the user) wants to access the file, the OS verifies whether the user is authorized

- Other technique found in many OS: **Access Control Lists (ACL)**
  - ACL = list of users who are allowed to access a file
  - For files, Linux supports permission flags and ACLs

Principle of Least Privileges

- Access control rules can become very complex and it's easy to accidentally open a system too much
- **Principle of Least Privileges** = Define the access control rules such that users only have those access rights that they need to do their job
- Example:
  - DB admin can only modify the database configuration but not change the owner of a file
  - User "Peter" can only access /home/peter but not /home/mary
  - Web server can only access /home/www but not /home/peter
- Advantage of implementing least privileges: If an account or program is hacked, the damage is minimized

On network level

- Access control also exists for networks
  - In the course we will talk about firewalls to block unwanted network traffic

- *Principle of Least Route: "Any component should not have more network access rights than required for its function"*
  - Should make it difficult for an attacker to successfully reach the target system through the network

Attacks against Access Control

- Many ways possible:
  - **Physical** (steal the computer)
  - **Social engineering** (convince a legitimate user to give the resource or the access rights to you)
  - Exploiting **wrongly implemented** access control (guessing easy password, find account with too many privileges,...)
  - **Privilege escalation** = the attacker first hacks a user with less access rights and then obtains the access rights of another user with more rights
  - ...